

情報—情報セキュリティ管理

1. 本题考查的是信息安全管理规范（JIS Q 27002）中对物理和环境安全或系统运营资产的分类，具体涉及 "**サポートユーティリティ (Support Utilities / 支持实用程序)**" 的定义与范畴。

什么是支持实用程序（Support Utilities）？ 在机房、数据中心或服务器运维环境中，支持实用程序通常指为了保障信息处理设施（如服务器、网络设备）正常运转而不可或缺的**基础设施或公用配套支持服务**（例如电力、空调、供水等环境支持设施，或者是设备的维护保养服务）。

在本题的语境下：服务器室的空调（サーバ室の空調）属于为服务器硬件正常运行提供环境温湿度控制的“支持设施/实用程序（Support Utility）”。

为什么其他选项是错误项？

- 选项 イ (サーバの保守契約 - 服务器的维护合同)：这属于供应商服务合同与供应链管理范畴，不是物理机房的运行支撑实用工具/设施。
- 选项 ウ (特権管理プログラム - 特权管理程序)：这属于软件层面的访问控制与身份验证管理（Access Control），属于软件工具而非环境设施。
- 选项 エ (ネットワーク管理者 - 网络管理员)：这是具体的岗位人员（HR/人员安全管理范畴），不是实用程序或设施。

“支持实用程序考点速记” 口诀：

- 看到 **サポートユーティリティ** → 脑子里瞬间锁定机房硬件：**「空調」** (空调) 或环境设施。

2. 本题考查的是信息安全管理体系国际标准 **JIS Q 27001 (ISMS)** 中，规范正文（条款 4～10）与附属书 A（管理目的及管理策）在认证符合性声明时的适用规则。

◦ **核心考点解析：**

- **规范正文（条款 4～10 / 規格本書の箇条4～10）：**规定了 ISMS 的通用核心要求（如组织环境、领导力、策划、支持、运行、绩效评价、改进）。因为这是构建信息安全管理体系的底线，**绝不允许任何形式的除外或删减，必须全部适用（全ての適用が必要である）。**
- **附属书 A（管理策 / 附属書A "管理目的及び管理策"）：**列出了大量的参考控制措施。因为每个公司的业务形态、物理环境不同，并不需要照单全收，**只要有正当合理的理由，就可以把不适用的管理措施进行除外（妥当な理由があれば適用除外できる）。**

“JIS Q 27001 适用要否考点速记” 口诀：

- 看到 **规格正文 (箇条4～10)** → 闭眼选：**「全て適用」** (全部适用)。
- 看到 **附属书 A (附属書A)** → 闭眼选：**「適用除外できる」** (有理由可除外)。

3. 本题考查的是信息安全管理体系统（ISMS）中经典的 **PDCA 循环（Plan-Do-Check-Act）** 各阶段的具体划分与实际应用。

◦ **核心考点解析：**

■ **PDCA 循环的四个阶段含义：**

1. **P (Plan / 计划)：**建立信息安全方针、目标、过程和程序。
2. **D (Do / 实施与运行)：**实施 ISMS 的方针、控制措施、过程和程序。
3. **C (Check / 检查)：**根据方针、目标和实践经验对过程进行评审和监视（例如本题中的**内部审计发现问题**）。
4. **A (Act / 改进/处置)：**针对审计或评审中发现的不符合项，采取**纠正措施（是正处置）**，对体系进行改进和完善。

为什么“选项 工 (A - Act)”是正确答案？

◦ **深度拆解：**

- i. **发现问题（C阶段）：**题目中提到“通过監査（审计）指摘を受けた（受到了审计指摘/发现违规）”，审计和检查属于 **Check (C)** 阶段的工作。
- ii. **解决并改进问题（A阶段）：**题目问的是“これを是正して退職の都度削除するように改める（将其纠正改为每次离职即时删除）”，这属于针对审计发现的问题采取的**纠正与改进措施（是正处置 / Action）**。因此，将做法改掉、优化流程属于 **Act (A)** 阶段。完美契合！

“PDCA 纠正考点速记” 口诀：

- 看到 **監査で指摘** (审计指摘/发现问题) → 对应 **Check (C)**。
 - 看到 **是正して改める** (纠正并修改/改进) → 脑子里瞬间锁定：**「A (Act)」**。
4. 本题考查的是信息安全管理体系统国际标准 **JIS Q 27001（ISMS 要求事项）** 中关于“情報セキュリティ目的の達成のための計画を策定する際の要件（策划信息安全目标实现计划时必须决定的事项）”。

核心考点解析：

- 在 JIS Q 27001 的标准条款（通常为 6.2 节“信息安全目标及其实现的策划”）中明确规定，当组织策划如何实现信息安全目标时，针对每一个目标计划，必须确定以下要素：
 - i. 实施什么事项（何をやるか）
 - ii. 需要什么资源（必要な資源）
 - iii. 谁来负责（責任者）
 - iv. 何时完成（達成期限）
 - v. 结果如何评估（結果の評価方法）

- 题目中已经给出了“实施事項（实施事项）”、“責任者（责任者）”、“達成期限（达成期限）”，因此还需要决定的另外两项正是“必要的资源（必要な資源）”以及“结果的评估方法（結果の評価方法）”。

为什么“必要な資源”及び“結果の評価方法”是正确答案？

- **深度拆解：**这精准命中了 JIS Q 27001 标准条款 6.2 的原文硬性规定。要完成任何一个安全目标，光有计划、负责人和截止时间还不够，必须要有预算/工具支持（必要な資源），并且要定期检查干得怎么样（結果の評価方法）。完美契合第一个选项！

“ISMS 目标策划考点速记” 口诀：

- 看到 情報セキュリティ目的の達成のための計画 (信息安全目标达成计划) → 脑子里瞬间锁定黄金组合：「必要な資源」(资源) + 「結果の評価方法」(评估方法)。

5. 本题考查的是信息安全管理国际标准 JIS Q 27001 (ISMS 要求事项) 中关于 情報セキュリティ方針 (Information Security Policy / 信息安全方针) 的编制、沟通与发布规范。

核心考点解析：

- **什么是信息安全方针（Information Security Policy）？** 它是组织最高管理层关于信息安全工作的总纲领和方向。
- **它的核心管理要求是什么？** 依据 JIS Q 27001 标准（通常在 5.2 节“方针”中规定）：信息安全方针必须形成文件、传达到组织内所有员工以及相关的外部相关方（従業員及び関連する外部関係者に通知する），并根据需要进行评审和更新，而不是藏着掖着或者由个人随便编写。

为什么“従業員及び関連する外部関係者に通知する (通知员工及相关的外部相关方)”是正确答案？

- **深度拆解：**这精准命中了 JIS Q 27001 关于方针发布的硬性规定。信息安全方针不是公司内部见不得人的机密，相反，它必须被广泛传达和沟通。不仅公司的全体员工（従業員）需要知道，凡是涉及合作的外部相关方（関連する外部関係者）也必须被通知到，以确保大家遵守共同的安全底线。完美契合！

为什么其他选项是错误项？

- 选项 ア (作为机密信息进行严格管理)：信息安全方针本身是全员和外部需要知晓的纲领性文件，不是需要严密锁起来的机密情报（反而是要广泛通知的）。
- 选项 ウ (由各信息安全负责人分别编写)：安全方针代表最高管理层的意志和全公司的方向，必须由最高管理者（Top Management）批准发布，而不是由各个负责人各自随便写一套。
- 选项 エ (制定后无法进行 Review，因此要用不需要重新审视的内容来编写)：大错特错。任何管理方针都需要定期评审（見直し・レビュー），不可能存在“不能评审”的说法。

“信息安全方针考点速记” 口诀：

- 看到 情報セキュリティ方針 问怎么处理 → 脑子里瞬间锁定黄金词：「従業員及外部関係者に通知」（通知员工和外部相关方）。

6. 本题考查的是信息安全管理体系（ISMS / JIS Q 27001）中关于风险评估（リスクアセスメント）核心要素的定义与辨析，涉及“リスク (风险)”、“脅威 (威胁)”和“脆弱性 (漏洞)”三者的正确逻辑关系。

核心考点解析：

- 风险要素的官方定义：
 - 資産 (Asset)：需要保护的信息资产。
 - 脅威 (Threat / 威胁)：可能利用资产或控制措施中脆弱性的潜在原因（如黑客、自然灾害等）。
 - 脆弱性 (Vulnerability / 漏洞)：资产或控制措施中可被威胁利用的弱点。
- 风险评估（リスクアセスメント）的核心步骤：
 - i. リスク特定 (风险识别)：识别资产、威胁、脆弱性及其潜在影响。正如选项 ウ 所述：风险识别就是去确定“威胁（脅威）利用控制措施或资产的脆弱性（脆弱性に付け込むことによって）”会给信息资产带来什么样的影响。

为什么“选项 ウ (リスクの特定では, 脅威が管理策の脆弱性に付け込むことによって情報資産に与える影響を特定する。)”是正确答案？

- 深度拆解：这精准命中了 JIS Q 27001 关于风险识别（リスク特定）的规范原意。风险识别的本质就是把“坏蛋/威胁（脅威）”和“系统的软肋/漏洞（脆弱性）”联系起来，看它们结合后会对公司的资产造成多大破坏（与题目选项ウ的描述完美吻合）。

为什么其他选项是错误项？

- 选项 ア：错误地将“威胁的水平与发生可能性”归咎于“系统内部的技术管理策”。管理策是用来防御的，不是决定威胁源头和发生可能性的因素。
- 选项 イ：概念张冠李戴。自然灾害、システム障害、人為的過失这些属于“脅威 (威胁)”的范畴，而不是“脆弱性 (漏洞)”。
- 选项 エ：风险评估的处理方式通常分为四种（リスク回避、リスク低減、リスク保有、リスク移転），并不是简单粗暴地只分为“回避”和“低減”两种。

“风险要素识别考点速记” 口诀：

- 看到 リスクの特定 问定义 → 脑子里瞬间锁定：「脅威が脆弱性に付け込む」（威胁利用漏洞）。

7. 本题考查的是灾难恢复（Disaster Recovery / BCP）中两个核心指标之一的 RPO (Recovery Point Objective / 恢复点目标) 的定义与概念。

什么是 RPO（恢复点目标）？它指的是当灾难发生、系统恢复运转时，数据必须恢复到过去哪一个时间点（或状态）。也就是说，它衡量的是“我们最多能容忍丢失多长时间的数据（数据的“新鲜度”或“容忍丢失的数据量”）”。

它的亲兄弟 RTO（恢复时间目标）是什么？ RTO 指的是从灾难发生到系统重新恢复运行需要花费多长时间（即停机时间的忍耐极限）。

为什么“システムが再稼働したときに、災害発生前のどの時点の状態までデータを復旧しなければならぬかを示す指標”是正确答案？

- **深度拆解**：这精准命中了 RPO（Recovery Point Objective）的定义。它规定了在系统重新启动（再稼働）时，数据必须被恢复到灾难发生前的“哪一个时间点（どの時点の状態まで）”。这直接决定了数据备份的频率。完美契合！

“RPO 与 RTO 考点速记” 口诀：

- 看到 **RPO** → 脑子里瞬间锁定：「どの時点の状態までデータを復旧」（恢复到哪个时间点的数据）。
- 看到 **RTO** → 脑子里瞬间锁定：「どのくらいの時間以内に再稼働」（多长时间内重新开机）。

8. 本题考查的是日本网络安全应急响应与支撑机构——JPCERT コーディネーションセンター (JPCERT/CC) 所发布的针对企业和组织建立安全事件响应体制（CSIRT）的官方权威指导资料。

核心考点解析：

- **什么是 JPCERT/CC?** 日本负责协调和处理计算机安全事件的核心民间/半官方机构。
- **构建 CSIRT 体制的官方工具包是什么?** 为了帮助各类组织从零开始搭建应急响应团队（CSIRT），JPCERT/CC 专门编写并发布了一套包含实操指南、模板和流程说明的官方工具集，其标准名称即为 **CSIRT マテリアル (CSIRT Material / CSIRT 建设材料与指南)**。

“组建消防应急救援队的官方工具箱的比喻”：

- 如果公司突然着火（发生网络安全事故），需要成立一个应急小分队（**CSIRT**）。
- **JPCERT** 作为消防总局，专门发给企业一个百宝箱，里面装满了怎么组建小分队的说明书和图纸。这个官方百宝箱的名字就叫 **CSIRT マテリアル (CSIRT 建设材料)**。
- 只要看到“JPCERT”和“构建响应体制”连在一起，直接认准带有 **CSIRT** 字样的材料包即可！

“JPCERT 应急体制考点速记” 口诀：

- 看到 **JPCERT + インシデント対応体制の構築** (构建事件响应体制) → 脑子里瞬间锁定黄金词：「**CSIRT マテリアル**」。

9. 本题考查的是 IPA（日本信息处理推进机构）发布的“中小企業の情報セキュリティ対策ガイドライン (中小企业信息安全对策指南)”中关于信息资产 **機密性 (Confidentiality / 机密性)** 评估标准的应用。

核心考点解析：

- 题目给出了机密性评估值为 2 的判断标准（評価基準 2）：
 - “法律で安全管理が義務付けられている、又は、漏えいすると取引先や顧客への大きな影響、自社への深刻若しくは大きな影響がある。”

- 简而言之，评估值 2 对应的是“一旦发生泄露（漏えい），会对客户、合作伙伴或企业自身造成严重/重大影响”的极端重要资产（如核心机密设计图外泄）。
- 而其他如“营业额减少（可用性问题）”或“被公开过时信息”不属于机密性泄露造成的严重后果。

为什么“选项 工”是正确答案？

- 深度拆解：
 - 选项 工 的资产是：主力製品の設計図 (电子数据)。
 - 其判断理由是：「不正アクセスによって外部に流出すると、技術やデザインによる製品の競争優位性が失われて、製品の売上が減少する。(如果因非法访问流出到外部，导致失去产品技术和设计的竞争优势，进而造成重大打击与销售下降)」。
 - 这完全契合了“漏えい（泄露）”导致企业受到深刻或重大影响的定义，因此其机密性评估值必须判定为 2。完美契合！

为什么其他选项是错误项？

- 选项 ア (自社 EC サイト): 理由是 DDoS 攻击导致无法访问（可用性 / Availability 的问题，不是机密性泄露）。
- 选项 イ (自社 EC サイト): 目录列表暴露（Directory listing）让访客浏览了废版商品，属于轻微的信息暴露，达不到“深刻或重大影响”的级别。
- 选项 ウ (主力製品の設計図): 理由是设计人员擅自修改（这是完全性 / Integrity 的问题，即未经授权的篡改，而不是机密性泄露）。

“机密性评估值 2 考点速记” 口诀：

- 看到 機密性が評価値2 → 脑子里瞬间锁定两个黄金词：「漏えい」（泄露）+ 「設計図などの重要データ流出」（设计图等重要数据流出）。

10. 本题考查的是云安全管理国际标准在日本的国家标准——JIS Q 27017:2016（基于 JIS Q 27002 的云服务信息安全管理策实践规范）的适用范围与对象。

核心考点解析：

- 什么是 JIS Q 27017？它是专门针对云服务（Cloud Services）制定的安全管理指南。
- 它的适用对象是谁？云计算具有双向性。一个企业既可能是云服务的利用者（Customer / 采购和使用别人云服务的人），也可能是云服务的提供者（Provider / 向外提供云服务的人）。因此，无论你是“只用别人的云”还是“自己提供云给别人”，或者两者兼有，该标准全部适用。

为什么“外部のクラウドサービスを利用する事業者と、クラウドサービスを他社に提供する事業者とのどちらにも適用できる。”是正确答案？

- **深度拆解：**这精准命中了 JIS Q 27017 标准的适用哲学。云安全不仅关乎“卖云的人（Provider）”如何保障机房和多租户安全，也关乎“买云的人（Customer）”如何在云端安全配置和管理数据。因此，无论你是**利用外部云服务的企业**，还是**向外部提供云服务的企业**，这两类经营者都完全适用（どちらにも適用できる）。完美契合！

“JIS Q 27017 适用范围考点速记” 口诀：

- 看到 **JIS Q 27017** 问适用对象 → 脑子里瞬间锁定黄金词：**「どちらにも適用できる」** (无论是用云的还是提供云的，两者都适用)。

11. 本题考查的是日本网络安全情报共享与漏洞对策的核心机构——**JVN (Japan Vulnerability Notes / 日本漏洞联合通报网站)** 的主要职能与信息发布范围。

核心考点解析：

- **什么是 JVN？** JVN 是由 IPA（独立行政法人信息处理推进机构）和 JPCERT/CC 共同运营的一个漏洞信息门户网站。
- **它主提供什么信息？** 它专门负责收集、发布和通报**软件等产品的脆弱性相关信息以及相应的防范/对策信息（ソフトウェアなどの脆弱性関連情報や対策情報）**，是日本 IT 从业人员查阅漏洞和补丁的核心权威数据库。

为什么“选项 ウ (ソフトウェアなどの脆弱性関連情報や対策情報)” 是正确答案？

- **深度拆解：**这精准命中了 JVN（Japan Vulnerability Notes）的字面含义与官方定位。“Vulnerability”在日语里就是“脆弱性（漏洞）”。JVN 的核心工作就是汇集各种软件和系统的漏洞情报（脆弱性関連情報），并提供官方的修复和对策说明（対策情報）。完美契合！

“JVN 考点速记” 口诀：

- 看到 **JVN** → 脑子里瞬间锁定黄金词：**「脆弱性」**（漏洞/软肋）+ **「対策情報」**（对策信息）。

12. 本题考查的是信息安全管理术语标准 **JIS Q 27000:2014 (ISMS 术语)** 中对于“风险管理责任主体”的官方定义。

核心考点解析：

- 在 JIS Q 27000 的标准术语中，对风险的运营管理（リスクを運用管理する）承担最终责任、拥有相应问责制（アカウントビリティ）和决策权限（権限）的个人或实体，被官方定义为 **リスク所有者 (Risk Owner / 风险所有者)**。

为什么其他选项是错误项？

- **选项 ア (監査員 - 审计员)：**审计员负责独立检查和评估合规性，而不是对风险运营管理负有直接责任和决策权的人。
- **选项 イ (トップマネジメント - 最高管理者)：**最高管理者虽然对整个 ISMS 负总责，但具体到各个业务线和信息资产的具体风险运营管理，标准术语更精准地使用“风险所有者”。
- **选项 ウ (利害関係者 - 利益相关者)：**这是一个宏观概念（包括客户、供应商、员工等），涵盖面太广，不专指负责风险运营管理的具体责任主体。

“ISMS 风险责任人考点速记” 口诀：

- 看到 **リスクを運用管理する** (运营管理风险) + **アカウントビリティ及び権限をもつ** (具有问责与权限) → 脑子里瞬间锁定黄金词：**「リスク所有者」** (风险所有者)。

13. 本题考查的是信息安全管理术语标准 **JIS Q 27000:2014 (ISMS 术语)** 中关于 **トップマネジメント (Top Management / 最高管理者)** 的正确理解与定义。

什么是 ISMS 中的“最高管理者 (Top Management)”？在标准定义中，最高管理者是指“在最高层指挥和控制组织的一个人或一组人”。也就是说，它并不一定局限于某一个特定头衔的个人（比如不一定非得是代表取締役或系统部长），它可以是一个由多人组成的管理决策集体（組織を指揮し、管理する人々の集まりとして複数名で構成されていてもよい）。

为什么其他选项是错误项？

- 选项 ア (要求处于 ISMS 适用范围之外的独立立场)：大错特错。最高管理者恰恰是 ISMS 体系的最高决策者和推动者，不可能要求其游离于 ISMS 适用范围之外。
- 选项 イ (如果是企业，则无论 ISMS 范围如何，都必须是代表取締役)：过于绝对。虽然通常是最高决策层，但在标准术语定义中，它强调的是“指挥和控制组织的人或集体”，不强限定必须是某个法定代表头衔。
- 选项 ウ (必须是信息系统部门的长)：大错特错。ISMS 是全公司的管理体系，最高管理者是公司最高经营决策层，绝不只是区区一个“IT 部门经理”。

“最高管理者考点速记” 口诀：

- 看到 **トップマネジメント** (最高管理者) → 脑子里瞬间锁定：**「複数名で構成されていてもよい」** (可以由多人组成管理集体)。

14. 本题考查的是日本经济产业省和 IPA（信息处理推进机构）所策定的“**サイバーセキュリティ経営ガイドライン (网络安全经营指南)**”中关于企业安全治理责任边界的核心要求。

核心考点解析：

- 供应链安全 (サプライチェーンセキュリティ)**：网络安全不仅是企业自身（自社）的事。现代企业的业务往往与上下游供应商、外包商、合作伙伴盘根错节。因此，《网络安全经营指南》明确指出，企业在做好自身防护的同时，**有责任去确认和促进行业供应链中的业务合作伙伴 (サプライチェーンのビジネスパートナー)** 的安全对策实施状况，防止黑客通过薄弱的下游供应商作为跳板来攻击核心企业。

为什么“**自社のサプライチェーンのビジネスパートナーが行うセキュリティ対策 (自社供应链中商业合作伙伴所实施的安全对策)**”是正确答案？

- 深度拆解**：这精准命中了网络安全经营指南的核心原则之一——“供应链安全管理”。因为木桶效应，黑客经常会攻击防御较弱的供应商（Business Partners），再以此为跳板入侵大企业。所以指南要求企业必须把安全管理的视野延伸到供应链的上下游合作伙伴身上。完美契合！

为什么其他选项是错误项？

- 选项 ア (自社提供商品及服务个人用户所做的安全对策): 用户个人的终端由用户自己负责, 企业无法也无权强行去替个人用户实施或检查安全对策。
- 选项 イ (投资自社股东所做的安全对策): 股东提供的是资金, 不属于业务运营和技术供应链的安全管理范畴。
- 选项 エ (自社事业所邻近的地域社会所做的安全对策): 社区和邻里属于公共社会责任, 不属于企业业务供应链的安全监控对象。

“网络安全经营指南考点速记” 口诀:

- 看到 サイバーセキュリティ経営ガイドライン 问除了自身还要确认谁 → 脑子里瞬间锁定黄金词: 「サプライチェーンのビジネスパートナー」 (供应链商业伙伴)。

15. 本题考查的是信息安全风险管理与企业风险管理中对风险对策的两大分类: リスクコントロール (Risk Control / 风险控制) 与 リスクファイナンス (Risk Finance / 风险财务/资金财务对策)。

◦ 核心考点解析:

- リスクコントロール (风险控制): 侧重于“减少风险发生的可能性”或“减轻风险发生时的损失规模” (例如: 安装防火墙、制定应急预案、修补漏洞等技术或管理防范手段)。
- リスクファイナンス (风险财务/风险融通): 侧重于“当风险不幸发生、造成经济损失时, 如何通过财务手段来筹集资金、转移经济负担” (例如: 购买保险、建立应急准备金等金钱赔付与转移手段)。

为什么“システムが被害を受けた場合を想定して保険をかけた。(为了设想系统遭受破坏的情况而购买了保险)”是正确答案?

- 深度拆解: 这精准命中了“リスクファイナンス (风险财务)”的本质。购买保险 (保険をかける) 是通过外部金融和保险手段, 把风险带来的经济损失转嫁出去, 属于典型的“风险财务”对策。完美契合!

为什么其他选项是错误项?

- 选项 イ (投入资金用于抑制导致系统受损风险发生的对策): 这属于在源头上控制风险的发生, 是 リスクコントロール (风险控制)。
- 选项 ウ (向金融机构借款来支付系统恢复费用): 这是事后救急的债务融资, 不属于风险发生前制定的“风险财务对策 (如保险/准备金)”。
- 选项 エ (投入资金用于减小风险显现时系统受损程度的对策): 这属于降低损失严重性的控制手段, 也是 リスクコントロール (风险控制)。

“风险财务考点速记” 口诀:

- 看到 リスクファイナンス (风险财务) → 脑子里瞬间锁定黄金词: 「保険をかけた」 (买保险) 或资金筹措转移。

16. 本题考查的是日本国家级网络安全情报共享与合作框架——J-CSIP (Cyber Security Information sharing Partnership of Japan / 社区网络安全情报共享伙伴计划)。

◦ **核心考点解析：**

- **什么是 J-CSIP?** 它是日本 IPA（独立行政法人信息处理推进机构）作为“信息枢纽（情報ハブ）”，把特定行业、参与组织及其集团企业在日常中检测到的网络攻击、恶意软件等威胁情报汇集起来，并在参与组织之间进行安全共享的官方合作框架。

为什么“选项 ウ (J-CSIP)” 是正确答案？

- **深度拆解：**这精准命中了 J-CSIP 的核心定义。题干中给出了几个极其强烈的考场识别特征：① 由 **IPA** 充当信息枢纽（情報ハブになって）；② 在参与组织及其集团企业（参加組織及びそのグループ企業）之间共享网络攻击情报。这正是 **J-CSIP** 的全称与职能。完美契合！

为什么其他选项是错误项？

- **选项 ア (CRYPTREC):** 这是日本政府评估和推荐加密算法安全性的项目（Cryptography Research and Evaluation Committees），与网络攻击情报共享无关。
- **选项 イ (CSIRT):** 这是企业或机构内部设立的“计算机安全事件应急响应小组（Computer Security Incident Response Team）”，它是一个组织团队，而不是 IPA 统筹的情报共享合作计划。
- **选项 エ (JISEC):** 这是日本信息安全评价和认证中心（Information Technology Security Evaluation and Certification Scheme），负责 IT 产品安全性评价认证，不是情报共享框架。

“J-CSIP 考点速记” 口诀：

- 看到 **IPAが情報ハブになって集約** (IPA充当信息枢纽来汇集) → 脑子里瞬间锁定黄金词：**「J-CSIP」**。

17. 本题考查的是信息安全管理体系标准 JIS Q 27001:2014 (ISMS 要求事项) 中第 5 章 “リーダーシップ (Leadership / 领导力)” 的核心要求。

最高管理者 (Top Management) 的领导力与承诺 (リーダーシップ及びコミットメント)：标准明确规定，最高管理者不能仅仅当个“甩手掌柜”，必须在实际行动中证明自己对 ISMS 的支持。具体要求之一，就是要在组织内部**指挥和支持员工，使他们为 ISMS 的有效性贡献力量 (ISMSの有効性に寄与するよう人々を指揮し, 支援する)**。

为什么其他选项是错误项？

- **选项 イ (把 ISMS 与组织的其他业务流程分开来独立运营)：**大错特错。ISMS 必须与公司的业务流程紧密融合（集成），绝不能搞成孤岛式的“两张皮”。
- **选项 ウ (遵守信息安全方针)：**遵守方针是“全体员工”的义务，而领导力考查的是最高管理者如何去推动、指挥和领导他人，而不是仅仅把自己当成普通员工去“遵守”。
- **选项 エ (制定信息安全风险应对计划)：**风险应对计划通常是由具体的信息安全负责人或风险所有者在策划阶段制定的，不属于最高管理者本人“实证领导力与承诺”的核心法定举措。

“最高管理者领导力考点速记” 口诀：

- 看到 **トップマネジメント + リーダーシップ** (最高管理者的领导力) → 脑子里瞬间锁定黄金词：**「人々を指揮し, 支援する」** (指挥和支持人员)。

18. 本题考查的是信息安全管理体系统（ISMS）中核心纲领文件——情報セキュリティ基本方針 (Information Security Policy / 信息安全基本方针) 的定义与性质。

○ 核心考点解析：

- 什么是信息安全基本方针？它是指由最高管理层（Top Management）制定的、用来表明组织在信息安全领域的方向、承诺以及对全员要求的纲领性文件。
- 它的核心作用是什么？它规定了管理层对信息安全工作的战略方向和支持（情報セキュリティのための経営陣の方向性及び支持を規定する）。

为什么“情報セキュリティのための経営陣の方向性及び支持を規定する。(规定了为了信息安全而来自经营层的方向性及支持)”是正确答案？

- 深度拆解：这精准命中了 ISMS 中“信息安全基本方针”的官方标准定义。安全方针本质上是老板（经营层）下达的最高指示和战略方向，用以向内外部表明公司对信息安全的态度和坚决支持。完美契合！

为什么其他选项是错误项？

- 选项 ア (作为重要的基本方针机密文档，不让社内相关人员以外的人看到)：错误。正如我们之前的考题所学，信息安全方针必须通告给全体员工及外部相关方，而不是藏着掖着的绝密文件。
- 选项 イ (规定了信息安全基本方针，即便业务环境和技术发生变化也绝不能更改)：大错特错。商业环境和技术日新月异，基本方针必须随着环境变化而定期评审和修订（见直し），不可能“永不更改”。
- 选项 エ (针对特定系统进行风险分析，并描述其安全对策与系统运行详情)：这是具体的“风险评估报告”或“系统运行规范/实施计划”，而不是宏观的“基本方针”。

“信息安全基本方针定义考点速记” 口诀：

- 看到 情報セキュリティ基本方針 问定义 → 脑子里瞬间锁定黄金词：「経営陣の方向性及び支持」（经营层的方向性及支持）。

19. 本题考查的是信息安全风险评估与对策选择中的两大主流方法之一——ベースラインアプローチ (Baseline Approach / 基准线方法)。

○ 核心考点解析：

- 什么是ベースラインアプローチ（基准线方法）？它是指组织不针对每一个资产单独去做极其复杂的个性化风险分析，而是直接采用业界公认的、标准化的安全防护基准（Baseline），然后把“组织目前的现状（現状）”与“标准基准（望ましい対策）”进行对比，找出差距（ギャップ）并加以弥补。
- 它的优点与缺点：省时省力，不需要专家绞尽脑汁去算概率，但缺点是缺乏针对性。与其相对的是“非形式化风险分析（Informal Risk Analysis）”或“详细风险分析（Detailed Risk Analysis）”。

为什么其他选项是错误项？

- 选项 イ (容易受到现场人员经验或想法的影响): 这是主观性较强的“非形式化风险分析 (Informal Risk Analysis)”的特点, 而不是基准线方法。
- 选项 ウ (针对每个信息资产单独进行风险分析): 这是“详细风险分析 (Detailed Risk Analysis)”或基于资产的风险评估方法, 违背了基准线方法“不搞逐个资产精细计算”的初衷。
- 选项 エ (并用多种方法以提高分析效率和精度): 这是组合分析法或多方法混用的概念, 不是基准线方法本身的定义。

“基准线方法考点速记” 口诀:

- 看到 ベースラインアプローチ (基准线方法) → 脑子里瞬间锁定黄金词: 「現状とのギャップ」 (与现状的差距)。

20. 本题考查的是信息安全管理与企业治理中 **情報セキュリティポリシー (Information Security Policy / 信息安全策略)** 的定义、目的与合规性质。

◦ 核心考点解析:

- 什么是信息安全策略 (Security Policy)? 它是企业为了保护自身信息资产、达成预期的信息安全防护水平, 而明确制定的全员必须遵守的行为准则、判断标准以及方针规范 (**目標とするセキュリティレベルを達成するために, 遵守すべき行為及び判断についての考え方を明確にすることが必要である**)。

为什么“**目標とするセキュリティレベルを達成するために, 遵守すべき行為及び判断についての考え方を明確にすることが必要である。**” 是正确答案?

- 深度拆解: 这精准命中了信息安全策略 (Security Policy) 的核心本质与设立目的。企业为了达到设定的安全防线, 必须用制度明确告诉员工“什么能做、什么不能做 (遵守すべき行為)” 以及“遇到安全情况时怎么判断 (判断についての考え方)”。完美契合!

为什么其他选项是错误项?

- 选项 ア (企业安全策略根据公司法规定必须经股东大会批准): 大错特错。安全策略属于企业内部的管理规章制度和运营规范, 由管理层或安全委员会制定并推行, 不需要提交给股东大会 (株主総会) 审批。
- 选项 イ (企业安全策略必须针对每一个要引入的系统单独去定义): 错误。安全策略是全局宏观的、统一的顶层指导方针, 而不是针对单个系统的技术配置说明。
- 选项 ウ (必须对外部公开作为策略制定原因的信息系统脆弱性): 大错特错。系统的漏洞和脆弱性 (脆弱性) 属于核心机密, 绝对不能对外公开 (対外的に公表する), 否则会招致黑客攻击。

“信息安全策略定义考点速记” 口诀:

- 看到 セキュリティポリシー 问正确的描述 → 脑子里瞬间锁定黄金词: 「遵守すべき行為及び判断」 (应遵守的行为与判断)。

21. 本题考查的是信息安全基础概念与 JIS Q 27000（信息安全管理体系术语）中对信息安全基本属性的官方定义，具体涉及信息安全四大核心属性之一的 **真正性 (Authenticity)**。

◦ **核心考点解析：**

- **什么是真正性 (Authenticity) ？** 在标准术语定义中，真正性是指“确保实体（人、设备或系统）与其所声称的身份完全一致的特性（エンティティが、それが主張するとおりのものであるという特性）”。也就是说，它用来证明“你大爷依然是你大爷”、“这个服务器确实是官方服务器，而不是冒牌货”。

“真正性考点速记” 口诀：

- 看到「**主張するとおりのものである**」（正如其所声称的那样）→ 脑子里瞬间锁定黄金词：**「真正性」** (Authenticity / 验明正身)。

22. 本题考查的是信息系统安全管理中经典的 **“对账与核对审计（照合・突合）”** 逻辑。

◦ **长题目应对核心思路：**

- 抓终极目标：**题目的最终诉求是“**発見できるもの**（能够最切实发现退職者ID未被删除的遗漏情况）”。
- 核心逻辑链：**要想找出“谁已经离职了，但其系统 ID 却还活着（幽灵账户）”，我们必须比对两个维度的信息：
 - **维度一：**目前系统里究竟有哪些活着的 ID（即：谁占着账号）。
 - **维度二：**这些人里谁实际上已经不是本公司的在职员工了（即：谁已经离职了）。
- 因此，完美的组合必须是：“**系统实际拥有的 ID 清单**”去对撞“**现实中的在职/离职真实名册**”。

◦ **为什么“选项 ウ” 是正确答案？**

■ **深度拆解：**

- **资料 A：** **利用者 ID とそれが発行されている者の一覧**（系统实际发出的 ID 及持有者名单——代表“系统里现在有哪些账号在活着”）。
- **资料 B：** **組織の現在の所属者の名簿**（组织当前的在职人员名册——代表“现实中谁还在公司上班”）。
- **核对逻辑：**拿着“系统活着的ID名单（资料A）”去和“公司当前在职人员名单（资料B）”做对比（突き合わせ）。如果某个 ID 的持有者**不在**当前的在职名册（资料B）里，那就说明此人已经离职，其 ID 却没有被删除（即找出了**削除漏れ**）。完美契合！

◦ **为什么其他选项是错误项？**

- **选项 ア & イ：**用“当前在职名册”去对撞“离职申请书”或者“当前所属者名册”，无法全面核查出系统里已经被遗漏未删的僵尸 ID 全貌。

- 选项エ：用“系统 ID 名单”去对撞“离职申请书（削除申請書）”，但题目明确说了“存在**申请漏れ**（连离职申请本身都漏掉了的情况）”，如果只看申请书，那些连申请都忘记交的离职人员 ID 就永远查不出来了！所以必须用“当前在职名册（实际人在不在）”来兜底。

23. 本题考查的是信息系统外包（ITアウトソーシング）管理中，委任方（A社）与受托方（B社）在发生情報セキュリティインシデント（信息安全事件）时的责任划分与管理规范。

○ 核心考点解析：

- 在 IT 外包管理中，**服务级别协议 (SLA - Service Level Agreement)** 或外包合同必须明确规定应急响应的手续、联络路径和处理流程。
- **委任方的最终责任（責任主体）**：虽然系统日常运维交给了 B 社，但 A 社作为资产所有者，不能把安全事件的裁量权、应急程序完全甩手不管（交给 B 社自主裁量或靠个人经验），必须通过合同、SLA 或预先制定的规范来约束，确保双方在发生事故时有章可循、迅速联络。

为什么“选项イ”是错误的？（直击您的核心疑问）

- 选项イ的内容：情報セキュリティインシデントに迅速に対応するためにサービスレベル合意書(SLA)に緊急時のセキュリティ手続を記載せず，B社の裁量に任せた。（为了迅速应对信息安全事件，**在SLA中不记载紧急时的安全手续，而全部交由B社自由裁量。**）
- 为什么错？
 - i. “**不记载应急手续**”是极大的管理漏洞：在信息安全管理中，发生事故时双方必须有明确的预案和手续（手順），如果把紧急处理程序“不写进 SLA 并不加约束（手続を記載せず）”，完全放权让外包商自己看着办（**B社の裁量に任せた**），这属于典型的“甩手掌柜”行为。
 - ii. **缺乏统筹与合规**：一旦发生重大安全事故，委任方（A社）无法把控风险，外包商（B社）也可能因为缺乏规范程序而导致处置失当或责任扯皮。因此，把紧急安全手续写进 SLA 并加以规范才是正确做法，绝对不能“任由 B 社自由裁量”。

为什么“选项ウ”是正确答案？

- 选项ウ的内容：情報セキュリティインシデントの発生をA社及びB社の関係者に迅速に連絡するために，あらかじめ定めた連絡経路に従ってB社から連絡した。（为了向 A 社和 B 社的相关人员迅速通报安全事件的发生，**按照预先规定的联络路径由 B 社进行了通报。**）
- 为什么对？这体现了标准的外包应急管理规范：**事先规定好联络路径（あらかじめ定めた連絡経路）**，事故发生时按章办事、迅速通报。完美契合风险管理要求！

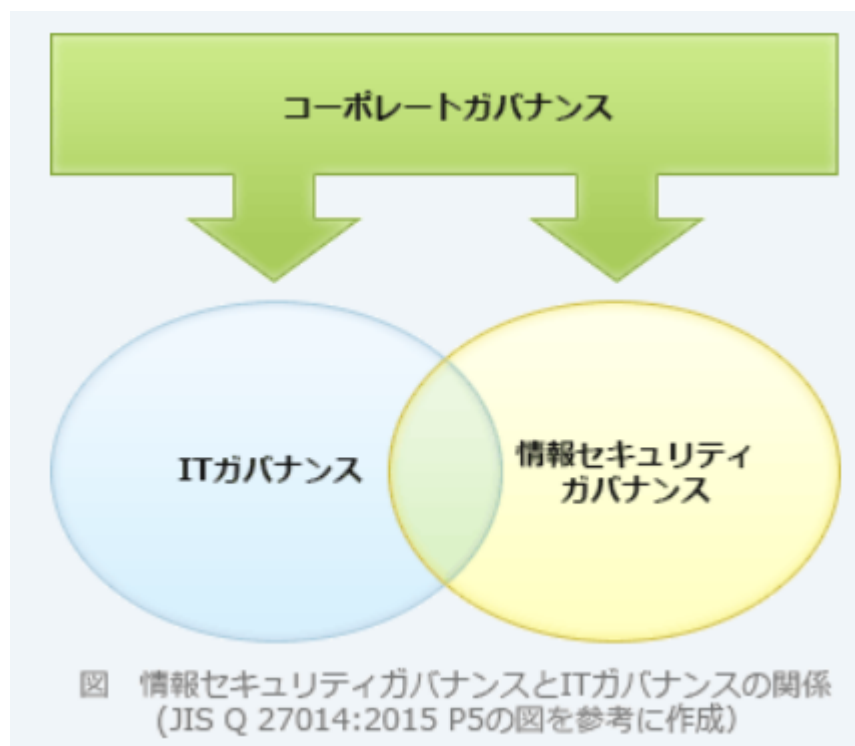
24. 本题考查的是信息安全治理标准 JIS Q 27014:2015（情報セキュリティガバナンス / 信息安全治理）中，**情報セキュリティガバナンス (信息安全治理)** 与 **ITガバナンス (IT治理)** 之间的范围包含与重叠关系。

○ 核心考点解析：

- **什么是 IT 治理（IT Governance）？** 它是组织治理的一个分支，涵盖了企业整体 IT 的战略、价值、风险和资源管理的方方面面。
- **什么是信息安全治理（Information Security Governance）？** 它是 IT 治理的一个重要子集和组成部分，专门聚焦于信息安全方向。
- 两者的关系并非“完全独立（不相交）”，也非“互相包含”，而是 **IT 治理的范围更广，其中一部分与信息安全治理重叠或包含（信息安全治理的范围包含在 IT 治理的范围内，或者说两者存在重叠部分）**。依据 JIS Q 27014 标准的定义，信息安全治理是 IT 治理的一部分，两者的范围存在重叠（重なる場合がある）。

“治理范围考点速记” 口诀：

- 看到 **情報セキュリティガバナンス** 和 **ITガバナンス** 的范围关系 → 脑子里瞬间锁定黄金词：**「重複する場合がある」**（范围存在重叠的情况）。



25. 本题考查的是信息安全管理体系统（ISMS / JIS Q 27005 或 JIS Q 27001）中关于 **リスク特定 (Risk Identification / 风险识别)** 阶段所需要识别和确定的核心对象。

○ **核心考点解析：**

- 在风险识别（リスク特定）阶段，组织必须系统性地识别出：
 1. **リスク源 (Risk sources / 风险源)**：可能引发风险的潜在源头（对应选项 d）。
 2. **リスクによって引き起こされる事象 (由风险引起的事件/事故场景)**：即可能发生什么坏事（对应选项 b）。
 3. **原因及び起こり得る結果 (事故的原因及可能带来的后果)**（对应选项 c）。

- 至于选项 a 的“**リスク対応に掛かる費用 (应对风险所需的成本/费用)**”，那是后续进入“风险应对策划（リスク対応）”阶段时才需要考虑的事情，不属于“风险识别（特定）”的范畴。因此，正确应识别的对象是 **b, c, d**。

“风险识别对象考点速记” 口诀：

- 看到 **リスクの特定** 问识别对象 → 记住：“**找源头(d)、看事件(b)、究原因和结果(c)，绝对不谈钱(a)**”！

26. 本题考查的是信息安全管理（ISMS）与组织级风险管理（リスクマネジメント）的基本原则与实施方法。

○ **核心考点解析：**

- **信息安全风险管理是一项全员工程：**信息安全绝不仅仅是 IT 部门或几个技术人员的事。它需要组织的全员分担各自的角色与职责，从上到下、全方位地在整个组织范围内共同推进（組織の全員が役割を分担して、組織全体で取り組む）。

为什么“选项 ウ (組織の全員が役割を分担して、組織全体で取り組む。)” 是正确答案？

- **深度拆解：**这精准命中了信息安全管理与风险管理的底层核心逻辑。安全没有旁观者，从最高管理层到基层员工，每个人都有各自的信息安全角色和责任，必须全公司上下齐心协力、共同参与（組織全体で取り組む）。完美契合！

为什么其他选项是错误项？

- 选项 ア (最终责任人应从现场的信息安全管理担当中挑选)：大错特错。信息安全的最终责任人（最终问责者）是最高管理层（Top Management / 经营层），而不是由底层的现场担当来承担最终责任。
- 选项 イ (作为从组织业务中剥离出来的单独活动来实施)：大错特错。风险管理和信息安全必须与企业的日常业务流程紧密融合，绝不能搞成“孤岛式的独立活动（切り離した単独の活動）”。
- 选项 エ (在统一的管理系统下，各部门规定各自独立的方针并各自独立实施)：错误。企业的信息安全方针和管理体系必须是全局统一、顶层规划的，而不是各部门各自为战、各搞一套“独立王国”。

“风险管理组织原则考点速记” 口诀：

- 看到问信息安全风险管理的正确描述 → 脑子里瞬间锁定黄金词：“**全員が役割を分担」「組織全体で取り組む**”（全员分担角色，组织整体共同推进）。

27. 本题考查的是风险管理国际标准 JIS Q 31000:2010（リスクマネジメントー原則及び指針 / 风险管理 原则及指南）中，为了使风险管理有效，组织在实施时应当遵循的核心原则。

○ **核心考点解析：**

- **JIS Q 31000 风险管理原则的核心精髓：**风险管理绝不能千篇一律、生搬硬套，它必须根据组织的外部与内部上下文环境、目标和实际情况定制。也就是说，**风险管理是根据组织量身定制的（組織に合わせて作られる）**。

为什么“选项 イ (リスクマネジメントは, 組織に合わせて作られる。)”是正确答案?

- **深度拆解**: 这精准命中了 JIS Q 31000 规范中关于“定制化 (Customized)”的原则。每个公司的业务、规模和面对的威胁都不同, 因此风险管理框架和流程必须根据特定组织的情况进行定制 (組織に合わせて作られる)。完美契合!

为什么其他选项是错误项?

- 选项 ア (风险管理是静态的, 并在发生变化时结束): 大错特错。风险管理是一个动态的、持续改进的循环过程 (动态且持续), 永远不会因为有变化而“结束”。
- 选项 ウ (风险管理是从组织的主要业务中分离出来的独立活动): 大错特错。风险管理必须紧密融入组织的所有业务流程中, 绝对不能搞成“孤岛式的独立活动” (这在前面的题目中也多次强调过)。
- 选项 エ (风险管理仅针对风险已经显现的情况): 大错特错。风险管理不仅要防范未然 (针对潜在风险), 更是一个全生命周期的管理, 不仅仅局限于“风险已经爆发 (顕在化した)”之后。

“JIS Q 31000 风险原则考点速记” 口诀:

- 看到 JIS Q 31000 问风险管理的正确原则 → 脑子里瞬间锁定黄金词: 「組織に合わせて作られる」 (根据组织量身定制)。

28. 本题考查的是由日本经济产业省制定的 “ソフトウェア管理ガイドライン (软件管理指南)” 中, 法人、团体等软件使用者应当实施的基本事项

核心考点解析:

- 在《软件管理指南》中, 企业或组织在管理软件资产时, 最基础、最核心的组织保障措施就是: **必须任命对安全和软件管理负有责任的“セキュリティ管理責任者 (安全管理负责人)”**, 并搭建妥善的管理体制 (セキュリティ対策に責任を負うセキュリティ管理責任者を任命し, 適切な管理体制を整備する)。

为什么其他选项是错误项?

- 选项 ア (为了保护软件免受病毒侵害, 对利用者开展相关法规与使用许可协议的教育启蒙): 虽然教育启蒙很重要, 但指南中针对软件资产管理的基础核心强调的是“建立责任体制与合规清单”, 而不是把教育防病毒作为首要基本事项。
- 选项 ウ (为了确认有无违法复制等, 以所有软件为对象实施使用状况审计): 审计是后续的检查监督环节 (Check), 而不是最基础的“建立管理体制”这一第一步。
- 选项 エ (为了防范利用软件漏洞的非法访问, 制定规定使用步骤和管理方法的软件管理规则): 虽然需要规则, 但指南中明确列出的首要基本组织事项是“任命责任人与建立体制”。

“软件管理指南考点速记” 口诀:

- 看到 ソフトウェア管理ガイドライン 问基本事项 → 脑子里瞬间锁定黄金词: 「セキュリティ管理責任者を任命」 (任命安全管理负责人)。

29. 本题考查的是信息安全管理标准 JIS Q 27002 / JIS Q 27000 中关于风险要素的基本术语定义，具体聚焦于「**脅威 (Threat / 威胁)**」的概念。

◦ **核心考点解析：**

- **什么是“脅威 (威胁)”**？它是指可能对信息资产或组织造成危害的潜在事件或行为的原因（或者说来源/源头）。例如黑客攻击、自然灾害等，都是导致损害发生的源头。

为什么“选项 ア (情報資産に害をもたらすおそれのある事象の原因)”是正确答案？

- **深度拆解：**这精准命中了 JIS Q 27000/27002 中对“**脅威 (Threat / 威胁)**”的标准学术定义。威胁就是“给信息资产带来损害的潜在事象的**原因/源头 (原因)**”。完美契合！

为什么其他选项是错误项？

- **选项 イ (情報資産に内在して、リスクを顕在化させる弱点)：**描述的是「脆弱性 (Vulnerability / 漏洞/软肋)」，即存在于资产内部、会被威胁利用的弱点。
- **选项 ウ (リスク対策に費用をかけないでリスクを容認する選択)：**描述的是风险处理中的「リスク受容 / リスク保有 (接受风险 / 容忍风险)」。
- **选项 エ (リスク対策を適用しても解消しきれず残存するリスク)：**描述的是「残留リスク (Residual Risk / 残留风险)」。

“风险要素定义考点速记” 口诀：

- 看到 **脅威 (威胁)** → 脑子里瞬间锁定黄金词：**「原因」** (源头/原因)。
- 看到 **脆弱性 (漏洞)** → 瞬间锁定：**「弱点」** (内部弱点)。

30. 本题考查的是美国国家标准与技术研究院 (NIST) 定义的云计算三大服务模型 (SaaS、PaaS、IaaS) 中，**用户 (利用企业系统管理者)** 对ゲストOS (Guest OS / 客户操作系统) 的设置与セキュリティパッチ管理 (安全补丁管理) 是否具有控制和实施权限。

核心考点解析：

- **IaaS (Infrastructure as a Service / 基础设施即服务)：**
 - 服务商提供最底层的计算、存储、网络等基础资源。
 - 用户可以在上面自由安装和运行任意的软件、ゲストOS (操作系统) 以及应用程序。因此，用户对 **OS 及其安全补丁拥有完全的控制权 (实施可)**。
- **PaaS (Platform as a Service / 平台即服务)：**
 - 服务商提供运行应用程序的平台 (如数据库、编程语言环境)。
 - 用户无法管理底层的操作系统 (OS) 或硬件，用户只能管理自己部署的应用程序。因此，**无法对 Guest OS 进行设置或打补丁 (实施不可)**。
- **SaaS (Software as a Service / 软件即服务)：**
 - 服务商直接向用户提供成品的应用软件 (如 Web 邮箱、Office 365)。

- 用户连底层平台和基础设施都碰不到，只能使用软件功能。因此，**完全无法对 Guest OS 进行任何设置（实施不可）**。

为什么“选项 イ (IaaS: 实施可, PaaS: 实施不可, SaaS: 实施不可)”是正确答案？

◦ 深度拆解：

- IaaS**：用户租用的是虚拟服务器的“毛坯房”，OS（操作系统）需要用户自己装、自己维护、自己打补丁。所以针对 Guest OS 的设置与补丁管理是「**实施可 (可以实施)**」。
- PaaS**：用户租用的是“精装修样板间（平台环境）”，OS 已经被云服务商管起来了，用户无权碰底层 OS。所以针对 Guest OS 的设置与补丁是「**实施不可 (无法实施)**」。
- SaaS**：用户租用的是“拎包入住的成品酒店（软件服务）”，连应用都是别人维护的。所以针对 Guest OS 的设置与补丁同样是「**实施不可 (无法实施)**」。

处理问题的排查表（NIST 三大云服务模型权限对比表）

云服务模型	用户能管什么？	用户能否对 Guest OS 进行设置与打补丁？
IaaS	基础设施 (OS、存储、自建应用)	可以 (能够直接管理 OS)
PaaS	仅限应用平台与自己开发的程序	不可以 (底层 OS 由服务商管理)
SaaS	仅限成品软件的功能使用	不可以 (完全由服务商托管)

云计算权限考点速记口诀：

- 看到 **ゲストOSの設定・パッチ管理** (客户OS设置与补丁管理) → 记住铁律：**只有 IaaS 能管底层 OS，PaaS 和 SaaS 统统管不着！**

31. 本题考查的是信息安全管理与风险管理体系中经典 **PDCA 循环（Plan-Do-Check-Act）** 的执行先后顺序与逻辑映射。

◦ 核心考点解析：

- 题干提到已经最初策定了执行计划（**Plan** 已经完成），接下来要对剩下的三个活动进行排序：
 1. **a. 実行計画に従ってリスク対策を実施する** → 按照执行计划落实风险对策，对应 **Do (实施)**。
 2. **b. 実施の効果を測定し、リスクマネジメントシステムの有効性を評価する** → 测量实施效果并评估体系有效性，对应 **Check (检查/评审)**。
 3. **c. リスクマネジメントシステムに関する是正・改善措置を実施する** → 实施纠正与改善措施，对应 **Act (处置/改进)**。
- 因此，严格遵循 PDCA 的铁律，其顺序必然是 **Do (a) → Check (b) → Act (c)**。

为什么“选项 ア (a → b → c)”是正确答案？

- 深度拆解：
 - 第一步：先干活/落实对策（a - Do）。
 - 第二步：干完后要检查/评估效果（b - Check）。
 - 第三步：根据检查出来的不足去改进/纠正（c - Act）。
 - 完美契合 Do → Check → Act 的标准闭环顺序！

32. 本题考查的是信息安全管理标准 JIS Q 27000 中定义的信息安全核心特性，焦点在于「否認防止 (Non-repudiation / 抗否认 / 防赖账)」。

- 核心考点解析：
 - 什么是“否認防止 (Non-repudiation)”？它是指能够证明某项操作、交易或事件的发生，以及参与该事件的实体身份，从而让当事人事后无法抵赖、不承认（証明可能にする）的特性。例如数字签名技术就是典型的否认防止手段。

为什么“选项 ア (ある利用者がシステムを利用したという事実を証明可能にする。)”是正确答案？

- 深度拆解：这句话的意思是“使某个利用者确实使用过系统的这一事实变得可以被证明”。这完美对应了“否認防止”的本质——防止用户事后“翻不认账”（说“我没用过、不是我干的”），通过日志或签名将其行为牢牢锁定。完美契合！

为什么其他选项是错误项？

- 选项 イ (意図する行動と結果が一貫性をもつ)：这不属于 JIS Q 27000 的核心安全特性标准表述（偏向于系统的某种行为一致性）。
- 选项 ウ (認可されたエンティティが要求したときにアクセスが可能である)：错误。这是「可用性 (Availability / 可用性)」的定义（确保授权者在需要时能够访问）。
- 选项 エ (認可された個人，エンティティ又はプロセスに対してだけ，情報を使用させる又は開示する)：错误。这是「機密性 (Confidentiality / 机密性)」的定义（确保只有授权人员才能访问或披露信息）。

“否認防止考点速记”口诀：

- 看到题目问 否認防止 → 脑子里瞬间锁定关键字：「証明可能」（能够证明）。

33. 本题考查的是信息安全管理标准 JIS Q 27002 中关于信息安全教育 and 培训（情報セキュリティに関する教育及び訓練）的合规实践。

核心考点解析：

- 在信息安全管理中，所有参与组织业务、能够接触信息资产的人员（包括正式员工、合同工、派遣员工等）都必须一视同仁地接受安全教育。
- 如果刻意将“从事与正式员工相同业务的派遣员工”排除在安全教育之外，会产生严重的安全漏洞，这是强化安全时必须进行改善（需要改善）的不当做法。

为什么“选项 工 (正規従業員と同様の業務に従事している派遣従業員を除いて、教育を実施していた。)”是正确答案?

- **深度拆解**：这句话的意思是“把从事与正式员工相同业务的派遣员工排除在外，实施了教育”。在信息安全管理中，派遣员工同样接触核心数据和系统，如果把他们排除在外，他们就会成为安全防范的“薄弱突破口”。从强化信息安全来看，这种做法存在安全隐患，**必须予以改善（改善が必要）**。完美契合！

“安全教育考点速记” 口诀：

- 看到问 “**需要改善的状况 (改善が必要な状況)**” → 脑子里瞬间扫描带歧视性、排他性的词汇。

34. 本题考查的是信息安全管理标准 JIS Q 27001:2014 的第 7.3 节 “**認識 (Awareness / 意识)**” 要求事项。

核心考点解析：

- 在 JIS Q 27001 中，组织下属的所有员工和相关人员不仅要接受培训，还必须对信息安全保持特定的“认识”。标准明确规定员工必须认识到三点：
 - i. **情報セキュリティ方針 (信息安全方针)**。
 - ii. **ISMS 的有效性对自身贡献（包括提升安全性能的好处）**。
 - iii. **不符合 ISMS 要求事项的后果（不合规的坏处）**。

“ISMS 意识要求考点速记” 口诀：

- 看到 **JIS Q 27001** 问“在组织下工作的人员必须具备什么认识（認識をもたなければならぬ）” → 脑子里瞬间锁定黄金词：**「情報セキュリティ方針」**（信息安全方针）。

35. 本题考查的是日本内阁于 2015 年 9 月制定的《サイバーセキュリティ戦略 (网络安全战略)》中所确立的**五つの基本原則 (五项基本原则)**。

核心考点解析：

- 该战略提出了网络空间的五项基本原则，其中包括：
 - i. **自由、公正及安全的网络空间**（确保自由流通与遵守规范）。
 - ii. **自主性与多方利益相关者合作**（各方共同参与，而不是由国家完全垄断）。
 - iii. **风险应对与持续改善**。
 - iv. **信息共享与合作**。
 - v. **国际合作**。
- 其中核心强调：网络空间绝不能被少数主体垄断，必须对所有寻求参与的人开放（**参加を求める者に開かれたもの**）。

为什么“选项 ア (サイバー空間が一部の主体に占有されることがあってはならず、常に参加を求める者に開かれたものでなければならない。)”是正确答案?

- **深度拆解**：这句话的意思是“网络空间绝不能被一部分主体所独占，必须始终向寻求参与的人开放”。这完美对应了网络安全战略五大原则中的“公开、开放、公平（自由与开放的网络空间）”原则。网络是大家的，不能搞垄断和封锁。完美契合！

为什么其他选项是错误项？

- 选项 イ (サイバー空間上の脅威は、国を挙げて対処すべき課題であり、サイバー空間における秩序維持は国家が全て代替することが適切である)：错误。网络安全虽然需要国家应对，但秩序维持并不是“由国家全部代办（国家が全て代替する）”，强调的是多方协作（Multistakeholder），企业和个人也有自主责任。
- 选项 ウ (サイバー空間においては、安全確保のために、発信された情報を全て検閲すべきである)：错误。主张“对所有发信信息进行全部审查（全て検閲すべき）”违背了网络空间的自由流通和隐私保护原则。
- 选项 エ (サイバー空間においては、情報の自由な流通を尊重し、法令を含むルールや規範を適用してはならない)：错误。前半句（尊重自由流通）虽然对，但后半句说“不得适用包括法令在内的规则与规范（適用してはならない）”是极其荒谬的，网络空间同样需要法律和规则约束。

“网络安全战略原则考点速记” 口诀：

- 看到 **サイバーセキュリティ戦略** (网络安全战略) 问基本原则 → 脑子里瞬间锁定黄金词：「一部の主体に占有されない・開かれたもの」（不被部分主体独占、开放的空间）。

36. 本题考查的是风险管理标准 **JIS Q 31000:2010**（风险管理—原则及指南）中关于核心概念「**残留リスク (Residual risk / 残留风险)**」的标准定义。

核心考点解析：

- 什么是“**残留リスク (残留风险)**”？在针对风险采取了应对措施（风险处理）之后，依然没有被消除、继续留存下来的那部分风险。顾名思义，“残留”就是“对策过后剩下的”。

为什么其他选项是错误项？

- 选项 ア (監査手続を実施しても監査人が重要な不備を発見できないリスク)：描述的是「監査リスク (审计风险)」，即实施了审计程序却没能发现重大漏洞的风险。
- 选项 イ (業務の性質や本来有する特性から生じるリスク)：描述的是「固有リスク (Inherent risk / 固有风险)」，即在不采取任何对策的情况下，业务本身所具有的风险。
- 选项 ウ (利益を生む可能性に内在する損失発生の可能性として存在するリスク)：描述的是「金融或投资领域的投机风险 / 财务风险」等概念，不符合 JIS Q 31000 中风险处理后的残留概念。

“残留风险考点速记” 口诀：

- 看到 **残留リスク (残留风险)** → 脑子里瞬间锁定黄金词：「**対応後・残る**」（应对之后、剩下的）。

37. 本题考查的是信息安全管理与业务连续性管理中 **コンティンジェンシープラン (Contingency Plan / 应急计划 / 业务连续性计划)** 制定与实施时的重要注意事项（留意点）。

什么是“**コンティンジェンシープラン (应急计划)**”？它是指当发生自然灾害、严重故障或网络攻击等紧急事态时，企业为了确保核心业务能够持续运行或尽快恢复而预先制定的行动方案。

核心编制原则：企业的资源（资金、人力、时间）是有限的，不可能把所有系统都同等对待。因此，制定计划时必须考虑系统的**重要性（重要性）与紧急性（紧急性）**，区分优先级来确定应对对象。

为什么“选项 ア (企業のすべてのシステムを対象とするのではなく、システムの復旧の重要性和緊急性を勘案して対象を決定する。)”是正确答案？

- **深度拆解：**这句话的意思是“不应该将企业的所有系统都作为对象，而是应综合考虑系统恢复的重要性与紧急性来决定对象”。这完全符合应急计划制定的经济性和现实性原则——资源有限，抓大放小，优先恢复核心系统。完美契合！

为什么其他选项是错误项？

- 选项 イ (災害などの対応のために、すぐに使用できるように、バックアップデータをコンピュータ室内又はセンター内に保存しておく)：错误。为了防止灾害时备份数据和主服务器一起被摧毁（比如火灾或水灾把机房全烧了），**バックアップデータ (备份数据)** 必须存放在**异地（オフサイト / 离线/不同机房）**，而不是和电脑室或中心放在同一个地方。
- 选项 ウ (バックアップの対象は、機密情報の中から機密度を勘案して選択する)：错误。备份的主要目的是为了防范数据丢失和系统恢复，选择备份对象时主要依据的是数据的**重要性与业务恢复的必要性（可用性/业务连续性）**，而不单单是“机密度（Confidentiality）”。
- 选项 エ (被害のシナリオを作成し、これに基づく“予防策策定手順”を策定する)：错误。应急计划（Contingency Plan）的核心是“事中及事后的应对与恢复（事后对策/恢复步骤）”，而不是侧重于制定“预防策（事前预防措施是别的规范做的事）”。

“应急计划考点速记” 口诀：

- 看到 **コンティンジェンシープラン (应急计划)** 问注意事项 → 脑子里瞬间锁定黄金词：「**すべてのシステムを対象とするのではなく…重要性和緊急性**」（不是全盘覆盖，看重要与紧急性）。

38. 本题考查的是业务连续性计划（BCP）制定过程中的核心步骤——**BIA (Business Impact Analysis / ビジネスインパクト分析 / 业务影响分析)** 的实施事项。

◦ **核心考点解析：**

- **什么是 BIA (业务影响分析)？** 它是指在制定 BCP 时，识别组织的关键业务活动，并评估一旦这些活动因系统故障或灾害中断时对业务造成的财务、声誉等影响。
- 其核心成果之一就是明确业务和系统能够容忍停多长时间，即确定最大可容忍停机时间（**RTO / 最大許容停止時間**）。

39. 本题考查的是日本独立行政法人信息处理推进机构（IPA）发布的《組織における内部不正防止ガイドライン (组织内部不正防止指南)》中针对**系统管理员 (システム管理者)**的防范不正当行为（如蓄意破坏、窃取数据）的有效管理对策。

◦ **核心考点解析：**

- 系统管理员拥有极高的特权（如最高权限、绕过常规限制），因此往往是内部不正当行为的高发人群。
- IPA 指南明确指出，为了防止系统管理员利用特权独自进行恶意操作且无人知晓，必须采取诸如“互相监督、禁止单人独立作业（相互監視・単独作業の制限）”等关键物理或逻辑防范措施。

为什么其他选项是错误项？

- 选项 ア (システム管理者間の会話・情報交換を制限する)：限制系统管理员之间的对话和信息交流是错误的。团队正常的工作交流与协作对于保障系统安全和发现异常至关重要，盲目限制会破坏团队协作。
- 选项 イ (システム管理者の操作履歴を本人以外が閲覧することを制限する)：限制除本人以外的人员查阅操作日志是错误的。恰恰相反，**操作履歴 (操作日志)** 必须由独立的安全审计人员或管理层进行交叉检查和监督，才能起到防范和威慑作用。
- 选项 ウ (システム管理者の長期休暇取得を制限する)：限制系统管理员获取长期休假是违规且不人道的。相反，强制休假（强制轮岗/Mandatory Vacation）往往是金融和IT审计中用来排查隐瞒违规行为的推荐做法，而不是“限制长期休假”。

“内部不正防止考点速记” 口诀：

- 看到 **内部不正防止** (内部不正防范) 结合 **システム管理者** (系统管理员) → 脑子里瞬间锁定黄金词：**「単独作業を制限する」** (限制单人作业)。

40. 本题考查的是风险管理中**リスク対策の手法 (风险应对手法)**的两大核心分类：**リスクコントロール (风险控制)** 与 **リスクファイナンス (风险融资 / 财务对策)**。

什么是“リスクファイナンス (风险融资)”？ 它是指当风险发生并造成经济损失时，通过财务或资金手段（如购买保险、设立准备金等）来弥补损失、转移财务负担的手法。

对比：リスクコントロール (风险控制) 侧重于降低风险发生的概率或减轻损失本身（如技术防护、物理隔离、废止高风险系统等）。

为什么其他选项是错误项（即属于风险控制 リスクコントロール）？

- 选项 ア (システム被害につながるリスクの発生を抑える対策に資金を投入する)：投入资金抑制风险发生，属于「リスク軽減 (风险减轻 / リスクコントロール)」。
- 选项 イ (リスクが大きいと評価されたシステムを廃止し、新たなセキュアなシステムの構築に資金を投入する)：废止高风险系统并重建，属于「リスク回避 (风险规避 / リスクコントロール)」。

- 选项 ウ (リスクが顕在化した場合のシステム被害を小さくする設備に資金を投入する): 投入資金减小潜在损失, 属于「リスク軽減 / 损失控制 (リスクコントロール)」。

“风险融资考点速记” 口诀:

- 看到 **リスクファイナンス** → 脑子里瞬间锁定黄金词: 「**保険を掛ける**」 (买保险 / 财务补偿)。

41. 本题考查的是信息安全与企业管理中 **リスクマネジメント (Risk Management / 风险管理)** 的基本原则、实施内容及其对象范围 (如纯粹风险与投机风险、风险融资的职责范围等)。

リスクファイナンス (风险融资): 主要负责在风险发生后通过财务手段 (如保险、准备金) 筹措资金来弥补损失, 而不是包揽风险管理过程中的 “一切费用 (如风险分析、风险控制等所有环节的费用)”。

リスク分析 (风险分析) 的对象: 在广义风险管理中, 不仅要关注只会带来损失的**純粹リスク (纯粹风险, 如火灾、自然灾害)**, 有时也需要对伴随收益与损失不确定性的**投機リスク (投机风险, 如商业投资)** 进行分析和管理的。

为什么 “选项 エ (リスク分析では純粹リスクにとどめず, 投機リスクも対象にする。)” 是正确答案?

- **深度拆解**: 这句话的意思是 “在风险分析中, 不仅局限于纯粹风险, 也将投机风险作为对象”。在现代综合风险管理框架中, 风险管理不仅要防范纯粹的灾害和故障 (纯粹风险), 还要应对企业经营和IT投资中伴随的各种不确定性 (投机风险)。这一说法符合风险管理的全面扩展趋势。完美契合!

为什么其他选项是错误项?

- 选项 ア (将来の損失発生の危険性は不確実なものであり, 対策費の予算ではなく損失額を見積もる): 错误。风险管理中必须同时估算 “对策费用的预算” 与 “潜在损失额”, 不能偏废。
- 选项 イ (投機リスクとは経営主体の管理外で発生するリスクなので, 内在するリスクは管理対象外とする): 错误。投机风险同样可以通过管理和决策来应对, 不能简单地将其排除在管理对象之外。
- 选项 ウ (リスクファイナンスでは, リスク分析, リスクコントロールなどのリスクマネジメントにかかる一切の費用の手当をする): 错误。风险融资 (Risk Financing) 的核心是筹措 “损失发生后的赔偿/财务应对资金”, 而不是包办风险分析和风险控制等 “一切费用”。

“风险管理实施内容考点速记” 口诀:

- 看到 **リスクマネジメントの実施内容** 问正确描述 → 脑子里瞬间锁定黄金词: 「**純粹リスクにとどめず, 投機リスクも**」 (不局限于纯粹风险,

42. 本题考查的是信息安全漏洞管理领域中极重要的标准标识符 **CVE (Common Vulnerabilities and Exposures / 共通脆弱性識別子)**。

什么是 CVE? 它是由美国MITRE公司维护的一个国际统一的漏洞信息数据库标准。

它的作用是什么？ 专门用于给各个产品中发现的具体安全漏洞（脆弱性）赋予一个唯一的全球通用编号（例如 CVE-2021-44228），以便于各国的安全漏洞门户网站（如 JVN）进行跨平台引用和管理。

“CVE 考点速记” 口诀：

- 看到 **CVE** 或 **共通脆弱性識別子** → 脑子里瞬间锁定黄金词：**「製品に含まれる脆弱性」**（产品中包含的漏洞）。

43. 本题考查的是日本信息处理推进机构（IPA）为了促进中小企业信息安全而设立的一项标志性自我声明制度——**SECURITY ACTION (安全行动)**。

什么是 SECURITY ACTION？ 它是面向中小企业制定的制度，鼓励企业参考 IPA 发布的《中小企业の情報セキュリティ対策ガイドライン (中小企业信息安全对策指南)》，**自主采取信息安全对策，并进行自己宣言 (自我声明)**。它分为两个星级（★ひとつ星、★★ふたつ星），旨在帮企业向外界展示其对信息安全的重视。

为什么其他选项是错误项？

- 选项 ア (ISMS適合性評価制度): ISMS (ISO/IEC 27001) 是一套面向大中型企业的全面信息安全管理体系认证制度，需要第三方机构进行严格审核认证，而不是中小企业的“自己宣言”。
- 选项 イ (ITセキュリティ評価及び認証制度): 即 **JISEC**，它是依据 ISO/IEC 15408 (CC标准) 对 IT 产品及系统的安全性和可靠性进行评估和认证的制度，与中小企业安全行动无关。
- 选项 ウ (MyJVN): 这是由 IPA 和 JPCERT/CC 运营的漏洞检查工具和漏洞信息分发框架，属于技术工具，不是企业的自我声明制度。

44. 本题考查的是 JPCERT/CC 发布的《CSIRTガイド》中关于 **CSIRT (计算机安全应急响应小组)** 按 **活动与服务对象分类** 的知识点，特别是其中的 **コーディネーションセンター (Coordination Center / 协调中心)** 的定义与职责。

什么是 コーディネーションセンター (协调中心)？ 它的核心职责不是直接面向普通企业或普通用户，而是在发生安全事件（インシデント）时，在多个不同的 CSIRT 之间充当枢纽，负责外部的信息联动、协调与统筹工作。

因此，它的服务对象（サービス対象）通常是“其他的 CSIRT（他の CSIRT）”。

イ	インシデントの傾向分析やマルウェアの解析，攻撃の痕跡の分析を行い，必要に応じて注意を喚起する。	関係組織，国又は地域
ウ	自社製品の脆弱性 ^い に対応し，パッチ作成や注意喚起を行う。	自社製品の利用者
エ	組織内 CSIRT の機能の一部又は全部をサービスプロバイダとして，有償で請け負う。	顧客

为什么其他选项是错误项？

- 选项 イ: 描述的是进行恶意软件分析、趋势分析并发出预警, 服务对象是相关组织、国家或地区。这对应的是 **分析中心 / 警报中心 (アナリシスセンター / ワーニングセンター)**, 而不是协调中心。
- 选项 ウ: 描述的是应对自身产品的漏洞、制作补丁并提醒用户, 服务对象是自社产品的利用者。这对应的是 **厂商 CSIRT / 产品安全事件响应组 (ベンダーCSIRT)**。
- 选项 エ: 描述的是作为服务提供商有偿承接组织内 CSIRT 的部分或全部功能, 服务对象是客户。这对应的是 **托管 CSIRT / 外包服务型 CSIRT (MSSP / 外部委託型)**。

45. 本题考查的是信息安全管理标准 **JIS Q 27000:2014 (情報セキュリティマネジメントシステム—用語)** 中关于 **リスク分析 (Risk Analysis / 风险分析)** 的官方标准定义。

什么是 リスク分析 (风险分析)? 按照标准定义, 它是指“理解风险的特质, 并决定风险等级 (リスクの特質を理解し, リスクレベルを決定するプロセス)”的过程。

它是风险评估 (Risk Assessment) 的一部分, 旨在搞清楚风险到底有多大、性质是什么。

为什么其他选项是错误项?

- 选项 ア (適切な管理策を採用し, リスクを修正するプロセス): 采用适当的管理策略并修正风险, 这对应的是“リスク対応 (风险应对 / Risk Treatment)”。
- 选项 イ (リスクが受容可能か又は許容可能かを決定するために, リスク及びその大きさをリスク基準と比較するプロセス): 为了决定风险是否可接受而将风险大小与标准进行比较, 这对应的是“リスク評価 (风险评价 / Risk Evaluation)”。
- 选项 エ (リスクを発見, 認識及び記述するプロセス): 发现、识别并描述风险, 这对应的是“リスクアセスメント (或广义的风险识别 リスク特定)”的第一步。

46. 本题考查的是信息安全管理系统 (ISMS) 标准演进的历史渊源, 具体考察详细管理策略 (詳細管理策 / 附属书 A 的控制措施) 最初所源自的国际标准编号。

什么是 ISMS 的详细管理策略? 在构建 ISMS 时, 企业需要参考一系列的具体安全控制措施。

其历史渊源是: 英国的 **BS 7799** 标准后来被国际标准化组织采纳, 成为了国际标准 **ISO/IEC 17799** (随后演变为 ISO/IEC 27002), 而日本的 ISMS 适合性评价制度中的详细管理策正是以它为基础制定的。

为什么“选项 エ (ISO/IEC 17799)”是正确答案?

- **深度拆解: ISO/IEC 17799** (后改版为 ISO/IEC 27002) 是国际上关于信息安全管理实践规范的标准, 它直接构成了 ISMS 中各种**详细管理策 (Security Controls)**的技术基准。完美契合!

为什么其他选项是错误项?

- 选项 ア (ISO 9001): 这是**质量管理体系 (QMS / 品質マネジメントシステム)**的国际标准, 与信息安全管理详细管理策无关。
- 选项 イ (ISO 14001): 这是**环境管理体系 (EMS / 環境マネジメントシステム)**的国际标准, 属于环保领域, 与信息安全无关。

- 选项 ウ (ISO/IEC 15408): 这是评估 IT 产品及系统安全性的标准（通称 **CC标准 / 共通基準**），常用于安全产品评估，而不是 ISMS 详细管理策略的源头。

在这一堆数字里，**17799** 这个编号长得最像一排“安全巡逻哨兵（17799 = 一起去巡逻救救）”。

47. 本题考查的是信息安全中**公开密钥密码方式 (公開鍵暗号方式)** 下的**秘密键 (秘密鍵)** 管理规范。

为了应对使用者发生事故（如丢失或遗忘），必须能够恢复秘密键 (秘密鍵を復元できること) —— 这意味着单靠使用者自己保管丢失了就找不回来了不行，必须由安全部门统一生成并妥善备份恢复。

为了防止安全管理员进行不正当行为（不正防止），必须建立防范机制 —— 这意味着不能把至关重要的秘密键完全交给某一个单独管理员保管（防止一个人独揽大权搞破坏），必须通过分散保管 / 多人分担（分割・分担保管）来互相制衡。

“秘密键保管考点速记” 口诀：

- 看到 秘密鍵を復元できる 加上 不正防止 → 脑子里瞬间锁定黄金词：「分割し，複数の…管理者が分担」（分割并多管理员分担）。

48. 本题考查的是 NIST（美国国家标准技术研究所）定义的云计算服务模型（SaaS、PaaS、IaaS）中，利用者（用户）所拥有的控制权与责任范围。

◦ 核心考点解析：

- **PaaS (Platform as a Service)**: 用户可以在平台上部署自己开发或购买的应用，拥有自己实现的应用程序以及托管环境的配置控制权。
- 题目给出的关键判定标准：
 1. 利用者が構築したアプリケーションについての責務を持つ（对构建的应用程序负责）→ SaaS、PaaS、IaaS 均符合。
 2. OSやDBMSについて一部の権限は認められるが修正プログラムの適用までの責務はない（对 OS 或 DBMS 虽被赋予部分权限，但没有应用补丁/修正程序的责任）→ 这一条是精髓：在 IaaS 中，用户必须自己全权负责 OS 的补丁和更新；而在 **PaaS** 中，底层 OS 和 DBMS 由云服务商（プロバイダ）负责维护和打补丁，用户只管开发和运行应用，因此“无需承担应用修正程序的责任”。这精准锁定了 PaaS！

为什么“**PaaS (Platform as a Service)**” 是正确答案？

◦ 深度拆解：

- 在 **IaaS** 中，用户连 OS 都要自己管理、自己打补丁。
- 在 **SaaS** 中，连应用程序都不是用户自己构建的。
- 而在 **PaaS** 中，用户拥有应用层的控制权，OS/DBMS 的底层维护交给了云服务商（用户虽然有部分配置权，但无需承担系统级的修正程序应用责任）。题目中的描述完全契合 PaaS 的责任边界。完美契合！



处理问题的排查表（云服务模型责任辨析表）

云服务模型 (Service Model)	用户对应用程序的责任	用户对 OS / DBMS 补丁的责任
IaaS	负责构建的应用程序	必须自己负责 OS 补丁与维护
PaaS	负责构建的应用程序	由服务商维护，用户无应用修正程序责任
SaaS	不由用户构建（服务商全包）	由服务商全包

“租毛坯房、精装房、拎包入住的比喻”：

- **IaaS（毛坯房）**：墙面坏了、地板漏水（OS 补丁）全得自己修。
- **PaaS（精装房带有物业管家）**：墙体结构和大楼基础设施（OS/DBMS 底层补丁）由物业（服务商）搞定，你只需要负责在里面摆放你自己的家具（部署应用程序）。
- 所以，看到「OSやDBMSについて…修正プログラムの適用までの責務はない」（对 OS/DBMS 没有打补丁责任，只需管自己应用），直接闭眼锁定 **PaaS**！

49. 本题考查的是信息系统风险分析（リスク分析）的标准实施步骤与先后逻辑。

- **核心考点解析：**
 - 在进行风险分析时，必须遵循严密的逻辑推进顺序：
 1. 首先要做好准备工作，**理解分析对象并制定分析计划（分析対象の理解と分析計画）**—— 对应 ⑤。
 2. 接着要找出系统中存在的**脆弱性的发现和识别（脆弱性の発見と識別）**—— 对应 ④。
 3. 然后分析如果发生事故会怎么样，即**事故态样的关联分析与损失额予想（事故態様の関連分析と損失額予想）**—— 对应 ③。
 4. 对潜在的损失进行分类并**损失的分类与影响度的评价（損失の分類と影響度の評価）**—— 对应 ①。
 5. 最后基于上述分析，进行**对策的探讨、评价和优先顺位的决定（対策の検討・評価と優先順位の決定）**—— 对应 ②。

为什么正确的顺序是“⑤ → ④ → ③ → ① → ②”？

- **深度拆解：**
 - 第一步必须是全局规划：⑤ **分析対象の理解と分析計画**（先了解对象和计划）。
 - 第二步寻找漏洞：④ **脆弱性の発見と識別**（找出弱点）。
 - 第三步推演事故：③ **事故態様の関連分析と損失額予想**（分析事故形态并预估损失）。
 - 第四步评估影响：① **損失の分類と影響度の評価**（对损失分类并评估影响度）。
 - 第五步提出对策：② **対策の検討・評価と優先順位の決定**（探讨对策并决定优先级）。

- 观察选项，选项工（被灰色划掉但顺序完整清晰：⑤ → ④ → ③ → ① → ②）完全符合这一科学的风险分析流程。完美契合！

“去医院看病全过程的比喻”：

- 第①步：先挂号了解病情（⑤ 理解与计划）。
- 第②步：医生检查你哪里免疫力低下（④ 发现脆弱性）。
- 第③步：推测如果感冒恶化会烧成什么样（③ 事故态样与损失额予想）。
- 第④步：评估对生活和工作影响有多大（① 损失分类与影响度评价）。
- 第⑤步：最后开药并决定是住院还是吃药（② 对策探讨与优先顺位决定）。

50. 本题考查的是由 IPA（信息处理推进机构）发布的《中小企业的信息安全对策指南》（中小企業の情報セキュリティ対策ガイドライン）中，经营者（老板）必须亲自履行的 7 大核心职责（経営者が行わなくてはならない7つの重要な取組み）。

◦ 核心考点与完整知识点扩展：

- 根据该指南，经营者作为组织的一把手，必须发挥领导力亲自抓安全。这 7 大核心取组包括：
 1. 制定组织整体的应对方针（組織全体の対応方針を定める）→ 对应选项中的 c。
 2. 确保安全对策所需的资源（预算、人才等）。
 3. 让担当者研究必要对策并指示执行。
 4. 对安全对策进行定期或随时的重新审视（定期・随時の見直しを行う）→ 对应选项中的 b。
 5. 利用业务外包或外部服务时，明确责任范围。
 6. 收集有关信息安全的最新动向（最新動向を収集する）→ 对应选项中的 d。
 7. 做好紧急时的内外联络方式及被害应对准备。
- 而选项中的 a（情報セキュリティ監査の目的を有効かつ効率的に達成するために、監査計画を立案する —— 制定信息安全审计计划）属于专业层面的执行事务，不包含在这 7 大经营者核心职责之内。

为什么包含 b、c、d 的“选项 工 (b, c, d)”是正确答案？

◦ 深度拆解：

- b（対策を定期又は随時に見直す）：完全契合 7 大取组中的第 4 点（定期・随時の見直しを行う）。
- c（方針を定める）：完全契合 7 大取组中的第 1 点（組織全体の対応方針を定める）。
- d（最新動向を収集する）：完全契合 7 大取组中的第 6 点（最新動向を収集する）。

51. 本题考查的是日本经济产业省于 2011 年公佈的“クラウドサービス利用のための情報セキュリティマネジメントガイドライン (云计算服务利用的信息安全管理指南)”的制定目的与核心背景。

在企业使用云计算服务时，往往会面临许多传统 IT 架构中没有的新安全隐患。

为了让云服务利用者（用户企业）能够顺利、安全地评估和实施信息安全对策，该指南通过补充通用的管理标准（如 JIS Q 27002 的管理策），为利用者提供切实的指导。

为什么“选项 ア (JIS Q 27002 の管理策を補完し，クラウドサービス利用者が情報セキュリティ対策を円滑に行えるようにする。)”是正确答案？

- **深度拆解：**这句话的意思是“补充 JIS Q 27002 的管理策略，使云计算服务利用者能够顺利实施信息安全对策”。因为云环境具有多租户、数据外包、基础设施不可控等特性，通用的 JIS Q 27002 无法完全覆盖云的特殊风险，因此经产省专门制定了该指南来对它进行**补充（補完）**，帮助企业用户顺利开展云安全对策。完美契合！
52. 本题考查的是 IPA《中小企业的信息安全对策指南》（中小企業の情報セキュリティ対策ガイドライン）中，关于由**基本方针（基本方針）**、**对策基准（対策基準）**、实施手順（実施手順）构成的组织信息安全政策（セキュリティポリシー）的层级与结构规范。

◦ **核心考点解析：**

- 信息安全政策通常分为三个层级：顶层的**基本方针**（规定方向）、中层的**对策基准**（规定要做什么）以及底层的**实施手順**（规定具体怎么做）。
- 在中小企业的实际运作中，如果组织规模较小，可以将“对策基准”和“实施手順”合并为 1 个层级，再加上“基本方针”共同构成**2 个层级（2階層）**的文档结构，以减轻管理负担。

为什么其他选项是错误项？

- 选项 ア (基本方針と対策基準は適用範囲を経営者とし，実施手順は適用範囲を経営者を除く従業員として策定してもよい)：基本方针和对策基准的适用范围通常是**整个组织（全社）**，而不能仅限于经营者，因此说法错误。
 - 选项 ウ (組織の取り扱う情報資産としてシステムソフトウェアが複数存在する場合は，その違いに応じて，複数の基本方針…を策定する)：“基本方针”代表全社统一的最高经营理念和方向，一个组织只能有一个，不能因为系统软件多就制定多个基本方针。
 - 选项 エ (初めに具体的な実施手順を策定し…最後に，基本方針を策定する)：政策的制定顺序完全颠倒了。正确的逻辑是**自上而下**：先定最高层的“基本方针”，再定“对策基准”，最后定最底层的“实施手順”。
53. 本题考查的是信息安全管理标准体系中通用标准与特定领域标准的差异。

◦ **核心考点解析：**

- **JIS Q 27002:2014** 是信息安全管理通用的管理实践指南，属于“万金油”式的通用标准。

- **JIS Q 27017:2016** 是在 JIS Q 27002 的基础上，专门针对云服务（クラウドサービス）的安全特性补充制定的扩展标准。
- 因此，JIS Q 27002 中没有记载、但专门在 JIS Q 27017 中记载的管理策，必然是**云服务固有的信息安全管理策（クラウドサービス固有の情報セキュリティ管理策）**。

“JIS 标准数字考点速记” 口诀：

- 看到标准代码 **JIS Q 27017** → 脑子里瞬间锁定黄金词：**「クラウドサービス」(云服务)**。

54. 本题考查的是信息安全管理体系 **ISMS (JIS Q 27001:2014)** 标准中，最高管理者（トップマネジメント）在定期主持管理评审（マネジメントレビュー）时，法律和标准明确规定必须纳入讨论和考量的内容（输入项）。

根据 JIS Q 27001 标准的 9.3 节（管理评审），最高管理者评审时必须考虑的事项主要包括：

- 以往管理评审采取的措施的状况（前回までのマネジメントレビューの結果ととった処置の状況）。
- 与信息安全相关的内外部环境的变化、以及干系人需求的变化。
- 信息安全绩效的反馈，包括：
 - 不符合及纠正措施的状况（発生した不適合及び是正処置の状況）。
 - 监视和测量的结果。
 - 内部审计的结果（内部監査の結果）。
 - 信息安全目标的实现情况（トップマネジメントが設定した情報安全目標）。
- 资源获取、持续改进的建议等。

综合表格中的组合，选项 **イ** 包含了：

“前回までのマネジメントレビューの結果ととった処置の状況（以往评审及措施状况）”、

“トップマネジメントが設定した情報セキュリティ目的（设定的安全目标）”

以及“発生した不適合及び是正処置の状況（发生的不符合及纠正措施状况）”。这三项全部是标准中明文规定的核心输入项。

“老板年终述职大盘点的比喻”：

- **管理评审（マネジメントレビュー）** 就像是公司老板（最高管理者）一年一度的**年终总结大会**。
- 开这个会时，老板最关心的三件事是什么？
 - “去年开会留下的任务办砸了吗？”（前回结果与措施）
 - “我们年初定下的小目标赚/做到没有？”（设定目标）
 - “今年捅了多少娄子、擦了多少屁股？”（不符合与纠正措施）

“管理评审事项考点速记” 口诀：

- 看到 **マネジメントレビューで考慮しなければならない事項** → 脑子里瞬间锁定三件套：“**上回结果 + 安全目标 + 不符合状况**”。

55. 本题考查的是日本网络安全体系中非常核心的一个民间/中立组织——JPCERT/CC（JPCERT コーディネーションセンター / 日本计算机应急响应小组协调中心）的职能与定位。

JPCERT/CC 是什么？ 它是一个独立于特定政府机关和企业的中立组织（特定の政府機関や企業から独立した組織）。

它的主要职责是什么？ 负责国内计算机安全事件（コンピュータセキュリティインシデント）的报告受理、应对支援、发生状况把握、攻击手法分析、以及防范重演对策的探讨与建言。

为什么“选项 ウ (特定の政府機関や企業から独立した組織であり、国内のコンピュータセキュリティインシデントに関する報告の受付、対応の支援、発生状況の把握、手口の分析、再発防止策の検討や助言を行っている。)” 是正确答案？

- **深度拆解：**这句话精准概括了 JPCERT/CC 的法定身份与核心业务。它不属于政府，也不属于某具体企业，而是作为一个独立的协调中心，专门接报、支援、分析和防范日本国内的网络安全事故（Incident）。完美契合！

为什么其他选项是错误项？

- 选项 ア (産業標準化法に基づいて経済産業省に設置されている審議会であり…)：基于产业标准化法在经济省设立的审议会，这描述的是日本产业标准调查会（JISC）等标准化机构，与 JPCERT/CC 无关。
- 选项 イ (電子政府推奨暗号の安全性を評価・監視し…暗号技術検討会などで構成される)：评估和监视电子政府推荐密码的安全性，这描述的是 **CRYPTREC**（密码技术研究会/项目），而不是 JPCERT/CC。
- 选项 エ (内閣官房に設置され、我が国をサイバー攻撃から防衛するための司令塔機能を担う組織である)：在内阁官房设立、承担国家网络攻击防卫司令塔功能的组织，这描述的是**内阁网络安全中心（NISC）**，而不是民间独立的 JPCERT/CC。

“JPCERT/CC 考点速记” 口诀：

- 看到 **JPCERT/CC** → 脑子里瞬间锁定黄金词：“**独立した組織**”（独立的组织）与“**インシデント**”（安全事件/事故）。

56. 本题考查的是信息安全管理体系 **ISMS 风险分析（リスク分析）** 的主要方法之一 —— **基准线方法（ベースラインアプローチ / Baseline Approach）**。

核心考点解析：

- **什么是基准线方法（ベースラインアプローチ）？**
 - 这是一种“对照标准模版”来评估风险的方法。它不从头到尾去计算复杂的资产价值、威胁和脆弱性，而是直接采用业界公认、已经公开发表的标准、指南或最佳实践（如 ISO/IEC 27002 等）作为安全基准线（Baseline）。

- 然后，检查自身组织实际实施的管理策略与这个标准之间的差距（**ギャップ分析 / 差距分析**），以此来评估和发现风险并采取对策。

为什么“选项 ア (公表されている基準などに基づいて一定のセキュリティレベルを設定し、実施している管理策とのギャップ分析を行った上で、リスクを評価する。)”是正确答案？

- **深度拆解**：这句话的意思是“基于已公布的标准等设定一定的安全水平，在与正在实施的管理策略进行差距分析（ギャップ分析）的基础上，来评估风险”。这完美命中了“基准线方法”的核心定义——对照标准、查漏补缺（做 Gap 分析）。完美契合！

为什么其他选项是错误项？

- 选项 イ (情報資産を洗い出し、それぞれの情報資産に対して資産価値，脅威，脆弱性及びセキュリティ要件を識別し，リスクを評価する。)：罗列信息资产并逐一识别资产价值、威胁、脆弱性和安全需求，这描述的是传统的**详细风险评估方法（詳細リスク評価 / Detailed Risk Analysis / 资产驱动方法）**，而不是基准线方法。
- 选项 ウ (複数のリスク分析方法の長所を生かして組み合わせ，作業効率や分析精度の向上を図る。)：结合多种风险分析方法以提高效率，这属于**组合方法（ハイブリッドアプローチ / 组合/混合方法）**。
- 选项 エ (リスク分析を行う組織や担当者の判断によって，リスクを評価する。)：完全依赖组织或负责人的主观判断，这描述的是**非正式/基于经验的评估方法（非形式的アプローチ）**。

“ISMS 风险分析方法考点速记” 口诀：

- 看到 **ベースラインアプローチ** → 脑子里瞬间锁定黄金词：**「ギャップ分析」**（差距分析）。

57. 本题考查的是日本密码技术评议组织——CRYPTREC（Cryptography Research and Evaluation Committees / 暗号技術検討会）的核心活动内容与职责。

○ **核心考点解析**：

- **什么是 CRYPTREC？** 它是日本官民一体推进的密码技术与评价组织。
- **它的主要职责是什么？** 负责对密码技术的安全性、实现性及利用实绩进行评价与探讨（**暗号技術の安全性，実装性及び利用実績の評価・検討を行う**），并制定和维护“电子政府推荐密码”名单（e-Government Recommended Ciphers）。
- 为什么其他选项是错误项？

选项 ウ (組織の情報セキュリティマネジメントシステムについて評価し認証する制度を運用する)：对组织的信息安全管理体系（ISMS）进行评估和认证并运营制度，这描述的是**ISMS 认证机构（如 JIPDEC 等）**。

选项 エ (認証機関から貸与された暗号モジュール試験報告書作成支援ツールを用いて暗号モジュールの安全性についての評価試験を行う)：使用工具对加密模块进行安全性评估测试，这描述的是密码模块测试实验室（CMVP相关测试机构），而非 CRYPTREC 的整体研究评价职能。

“CRYPTREC 考点速记” 口诀：

- 看到 **CRYPTREC** → 脑子里瞬间锁定黄金词：「**暗号技術の安全性**」（密码技术的安全性评估）。